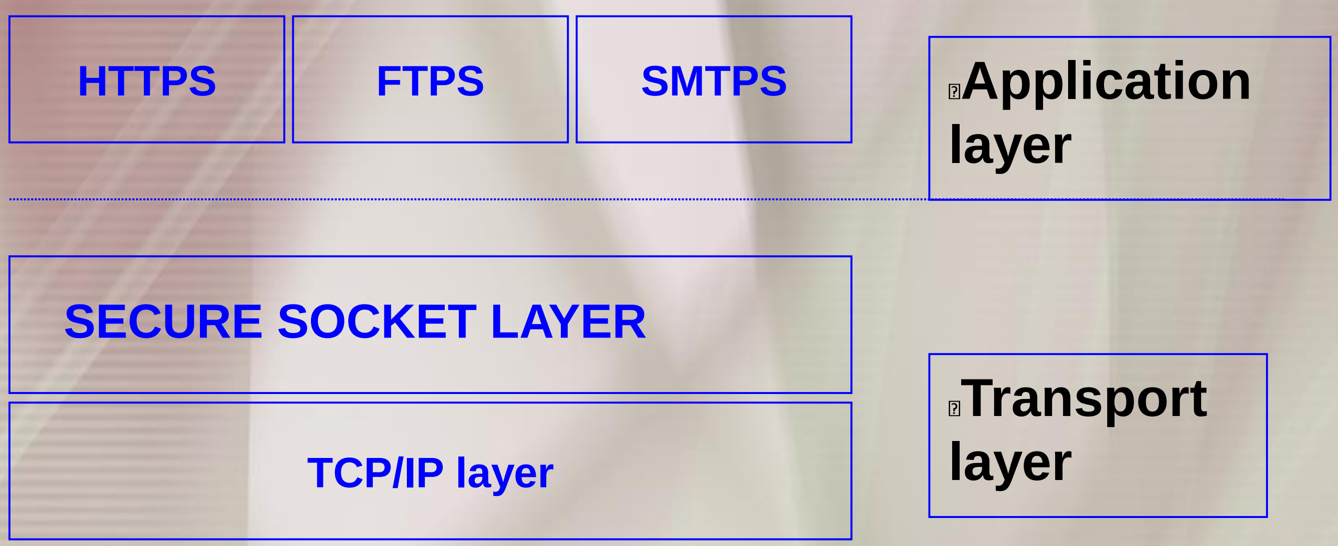
Secure Socket Layer

SSL is a secure protocol which runs above TCP/IP and allows users to encrypt data and authenticate servers/vendors identity securely



SSL components

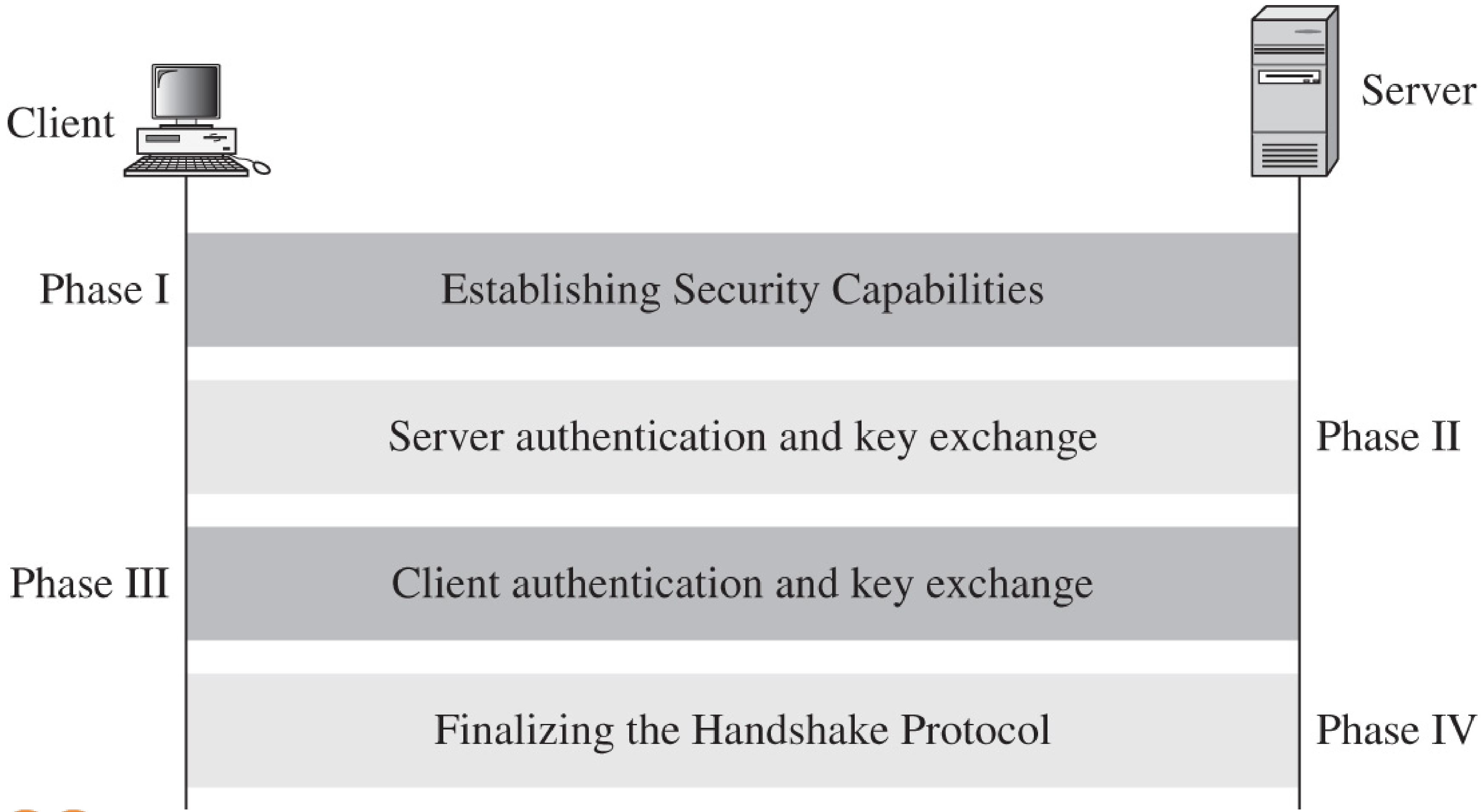
- SSL Handshake Protocol
  - negotiation of security algorithms and parameters
  - key exchange
  - server authentication and optionally client authentication
- SSL Record Protocol
  - fragmentation
  - compression
  - message authentication and integrity protection
  - encryption
- SSL Alert Protocol
  - error messages (fatal alerts and warnings)
- SSL Change Cipher Spec Protocol
  - a single message that indicates the end of the SSL handshake

SSL Handshake

SSL handshake verifies the server and allows client and server to agree on an encryption set **before** any data is sent out

SECURE SOCKET LAYER PROTOCOL

- Secure Socket Layer protocol for web communication
  - Latest upgrade: Transport Layer Security (TLS)
  - Same structure as SSL, somewhat more secure

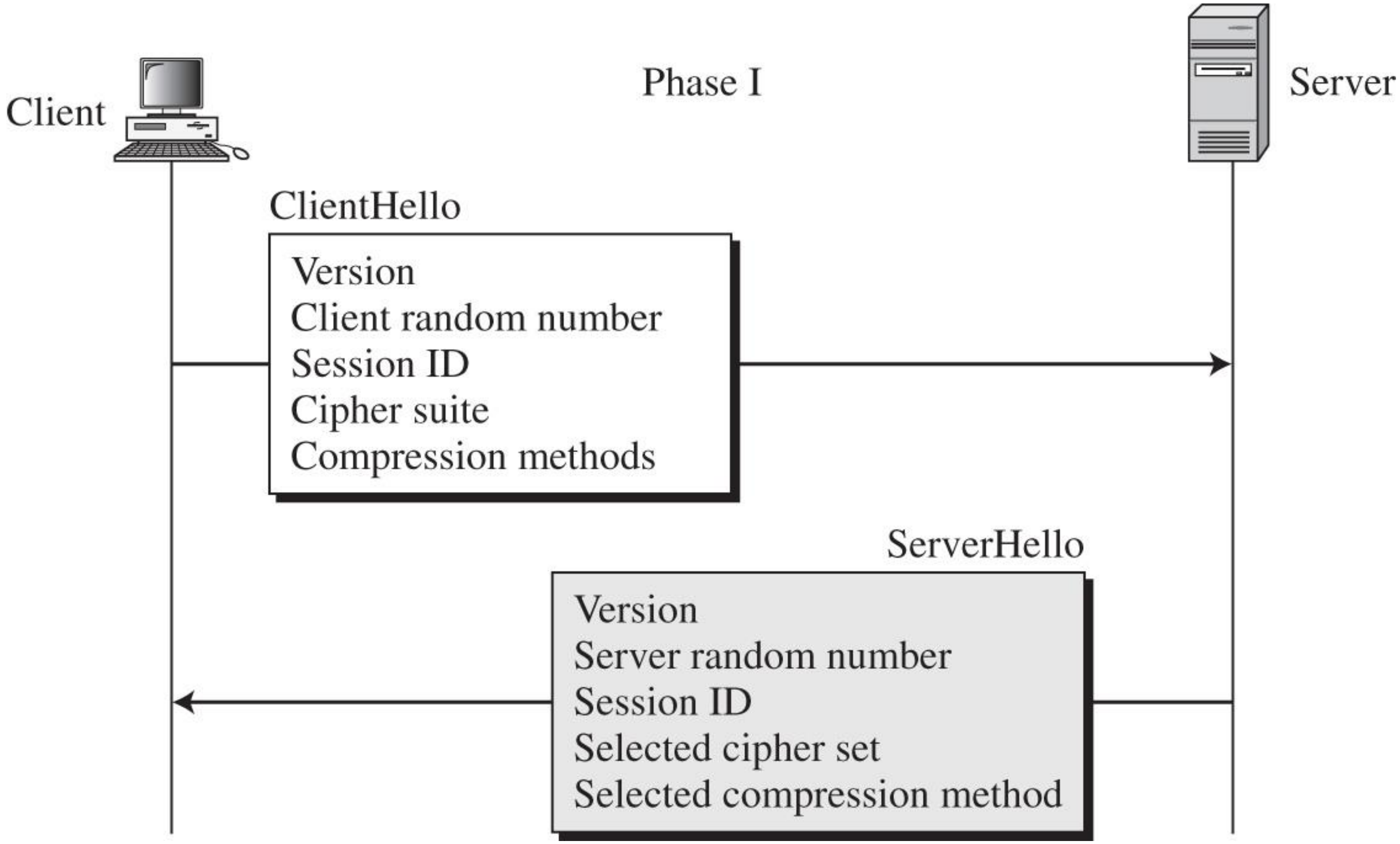


Nascenia IT

SSL HANDSHAKE PROTOCOL: PHASE 1

Phase 1: Information exchange

- Problem: Large number of encryption algorithms in use
  - How do client and server agree on which to use?
  - How does client tell server which ones it supports?



Nascenia IT

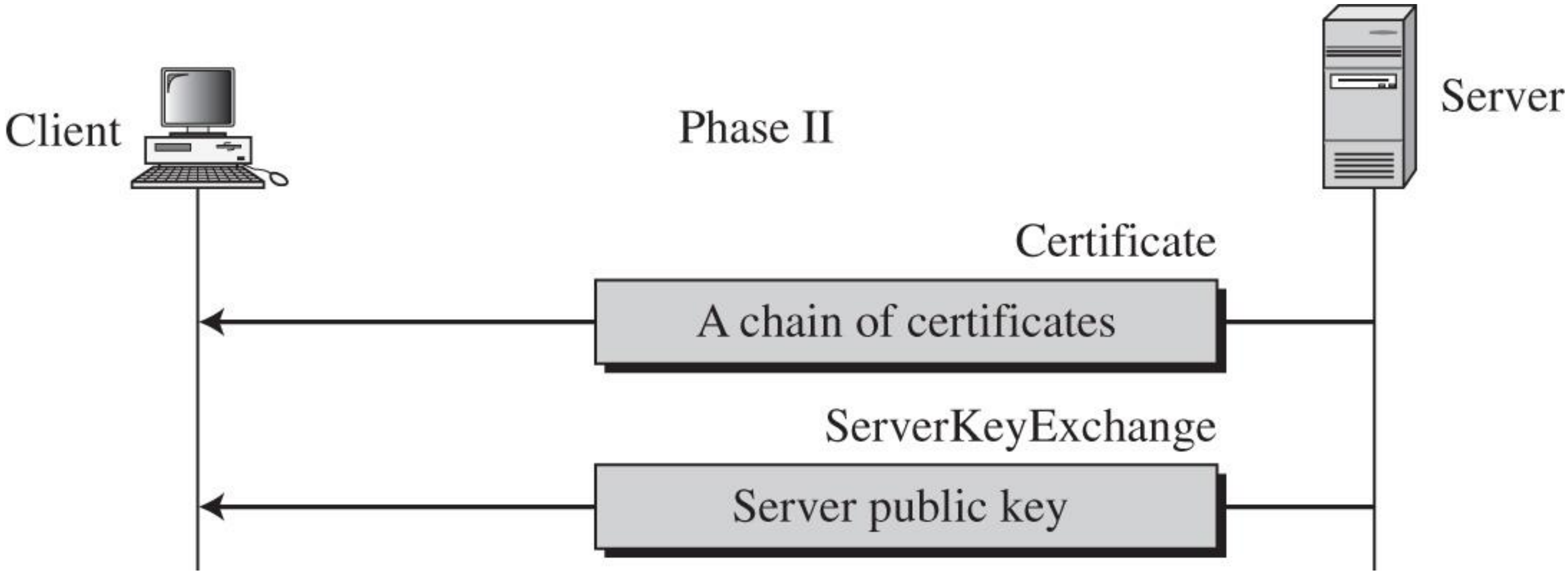
SSL PROTOCOL: PHASE 1

- Client passes preferred algorithms to server via https request
  - Public key encryption algorithms
  - Private key encryption algorithms
  - Hash algorithms
  - Compression algorithms
  - Also random number for key generation
- Server replies with algorithms that will be used
  - Also passes own random number

SSL PROTOCOL: PHASE 2

Phase 2: Server Identification and Key Exchange

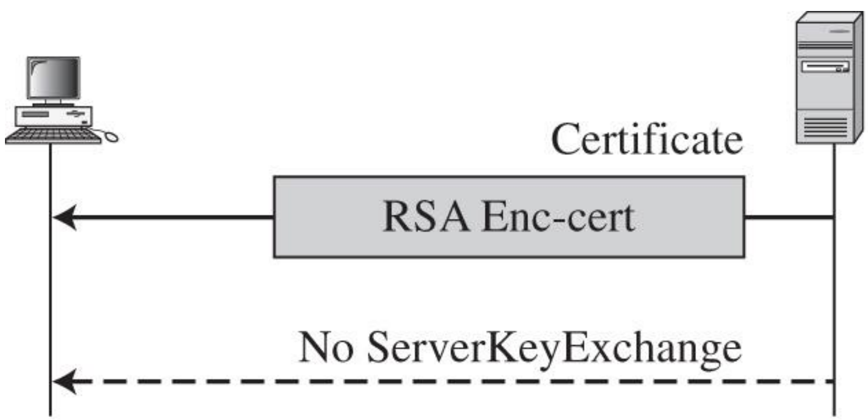
- Server passes their certificates to client
  - Client uses issuer public key to verify identity
  - Client retrieves server public key from certificate
  - Server may pass many certificates for authentication



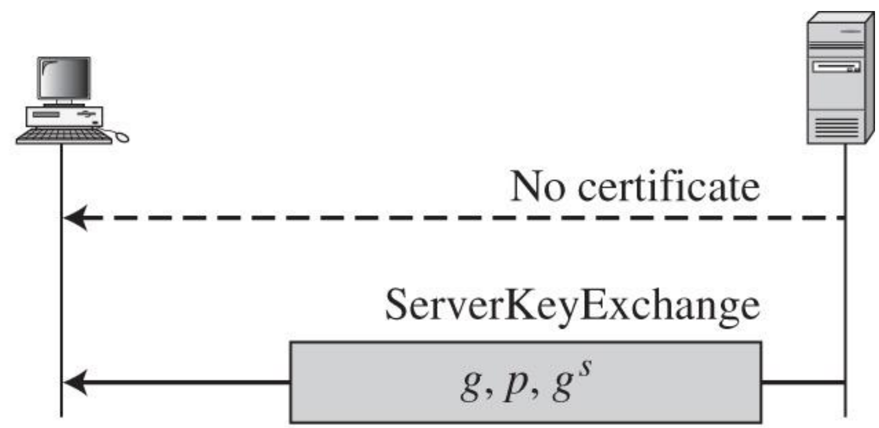
Nascenia IT

SSL PROTOCOL: PHASE 2

- If no certificate containing a public key, separate public key must be passed



Certificate contains RSA public key, so no separate key passed

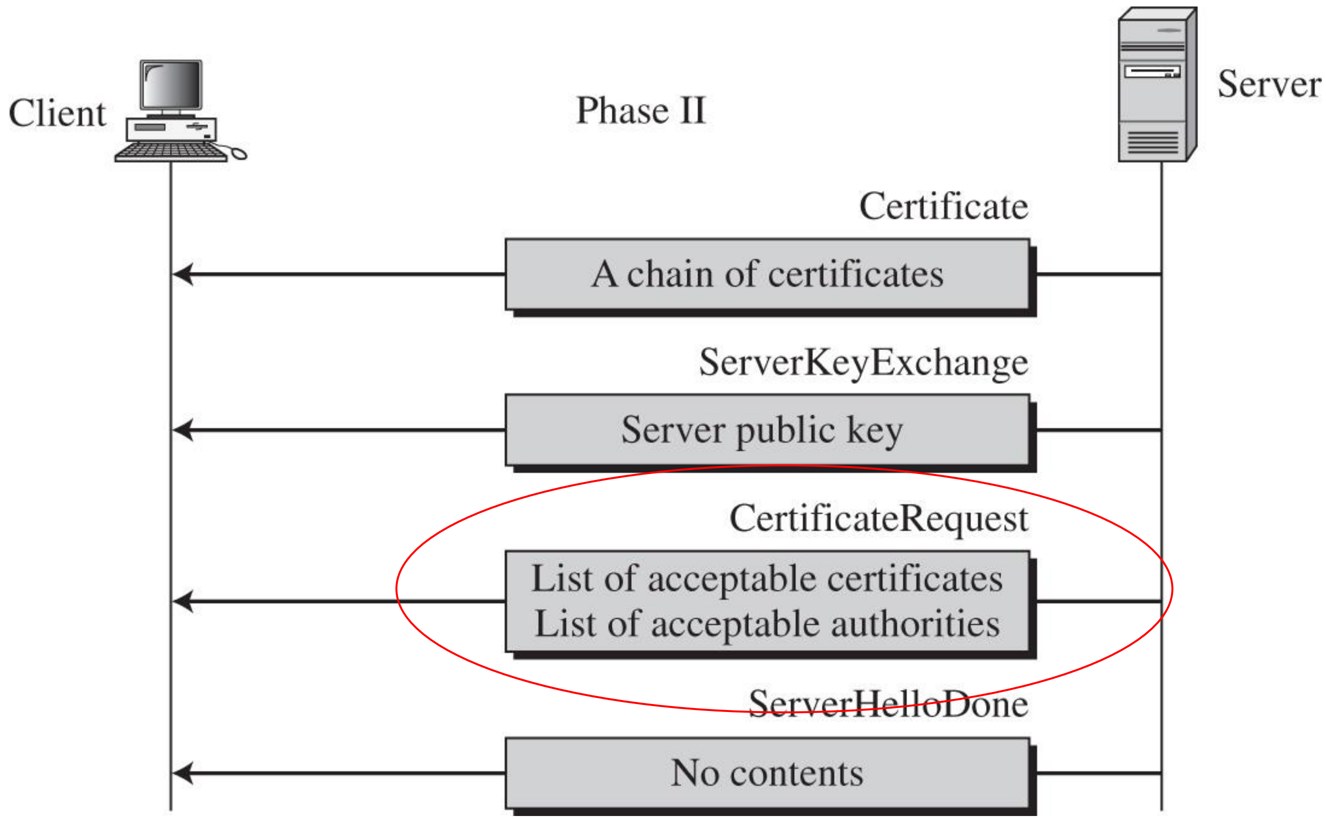


No certificate, so Diffie-Hellman key exchange parameters passed

Nascenia IT

SSL PROTOCOL: PHASE 2

- Server can also request appropriate <u>client certificates</u> to authenticate client
  - Online banking
  - Remote access to company database

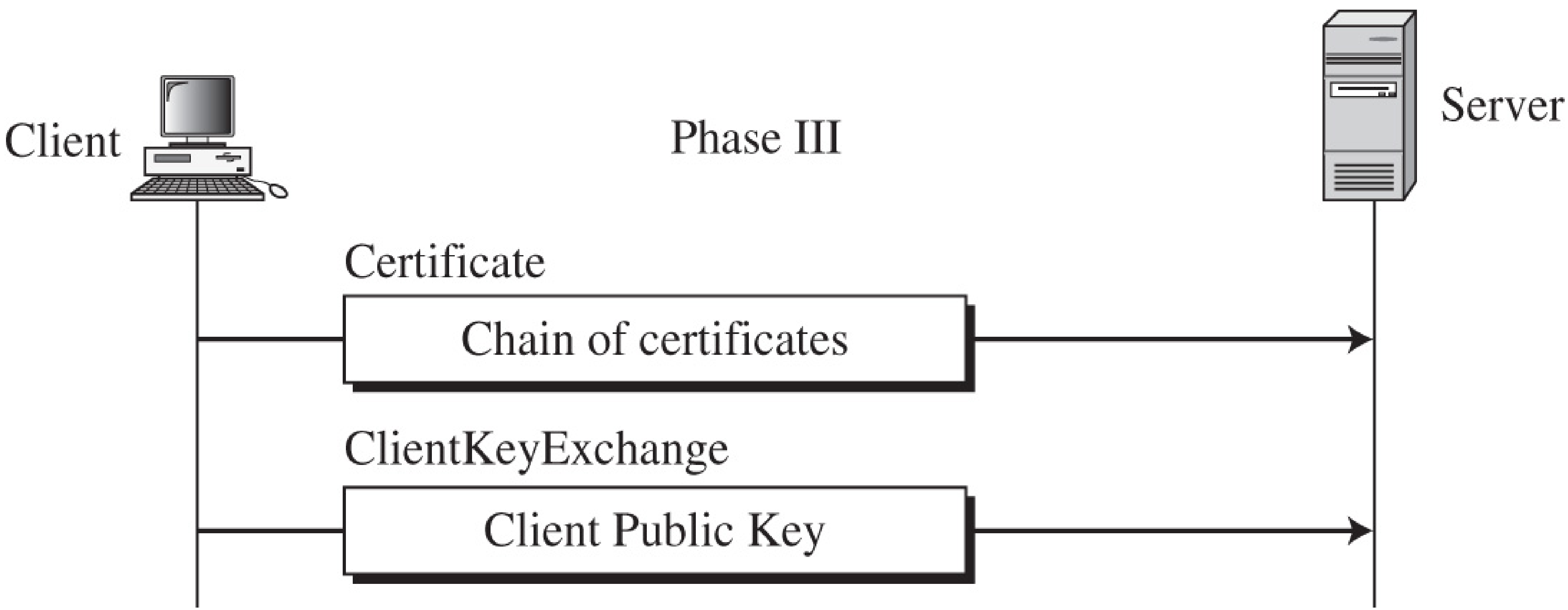


Nascenia IT

SSL PROTOCOL: PHASE 3

Phase 3: Client Identification and Key Exchange

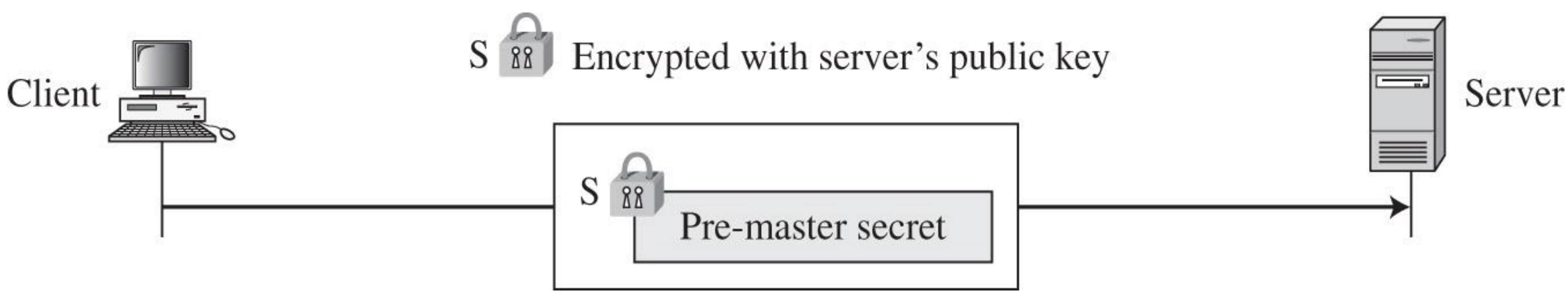
- Client sends certificate or public key if requested by server



Nascenia IT

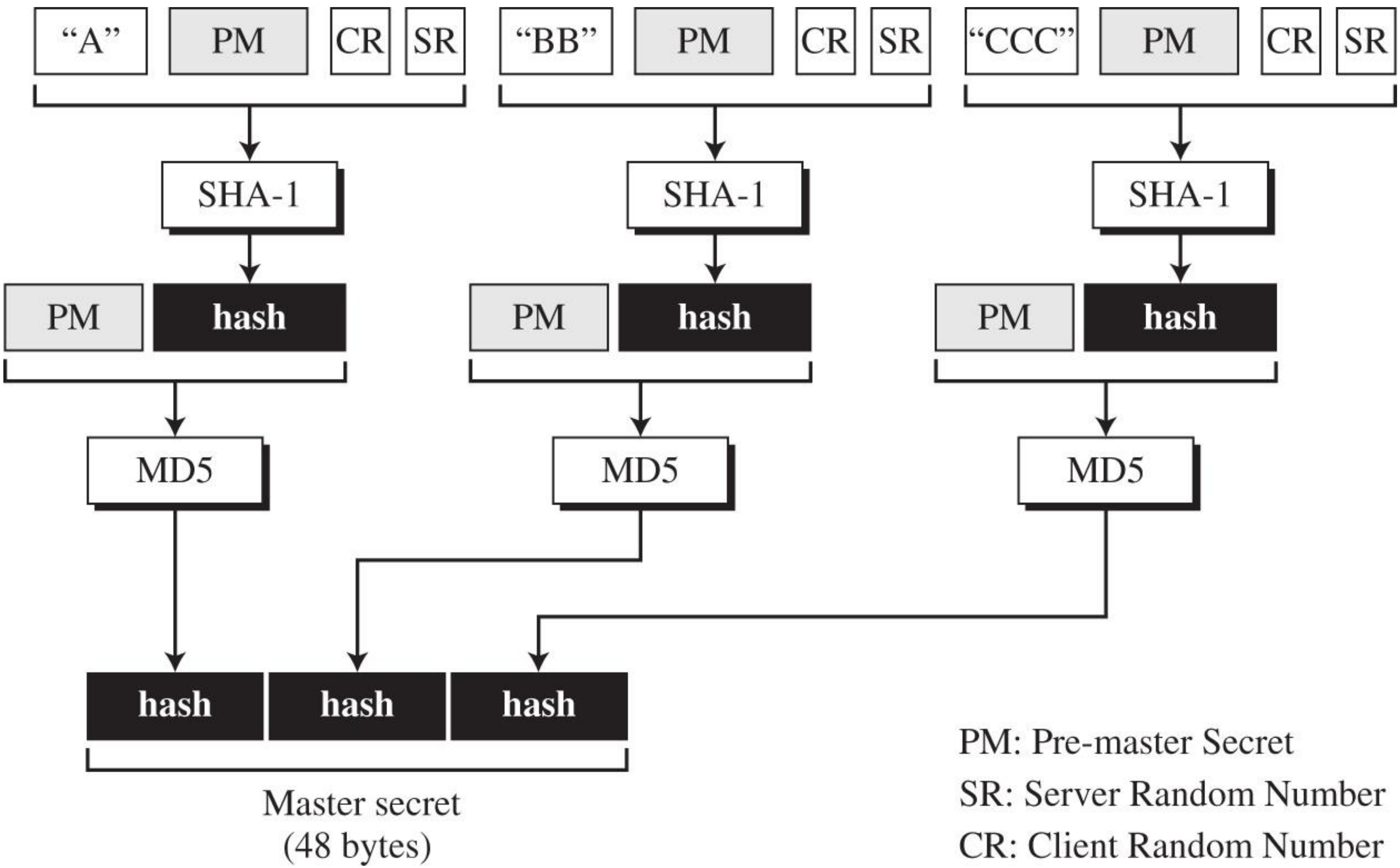
SSL KEY GENERATION

- Client generates “pre-master key”
- Sends to client encrypted with server public key
- Client and server use to generate master key used to create cipher keys
  - Also use client, server random numbers exchanged in phase 1

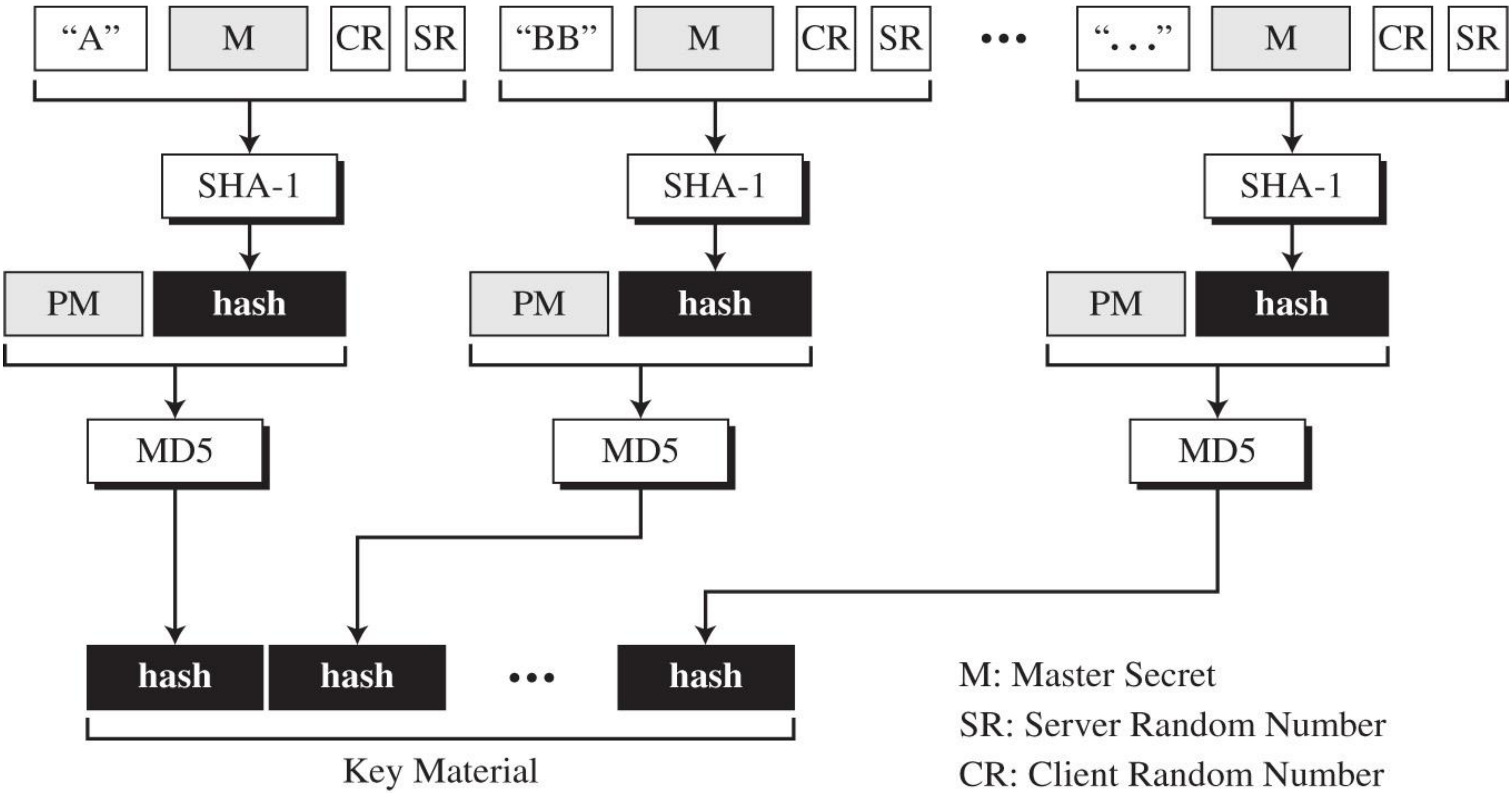


Nascenia IT

SSL KEY GENERATION



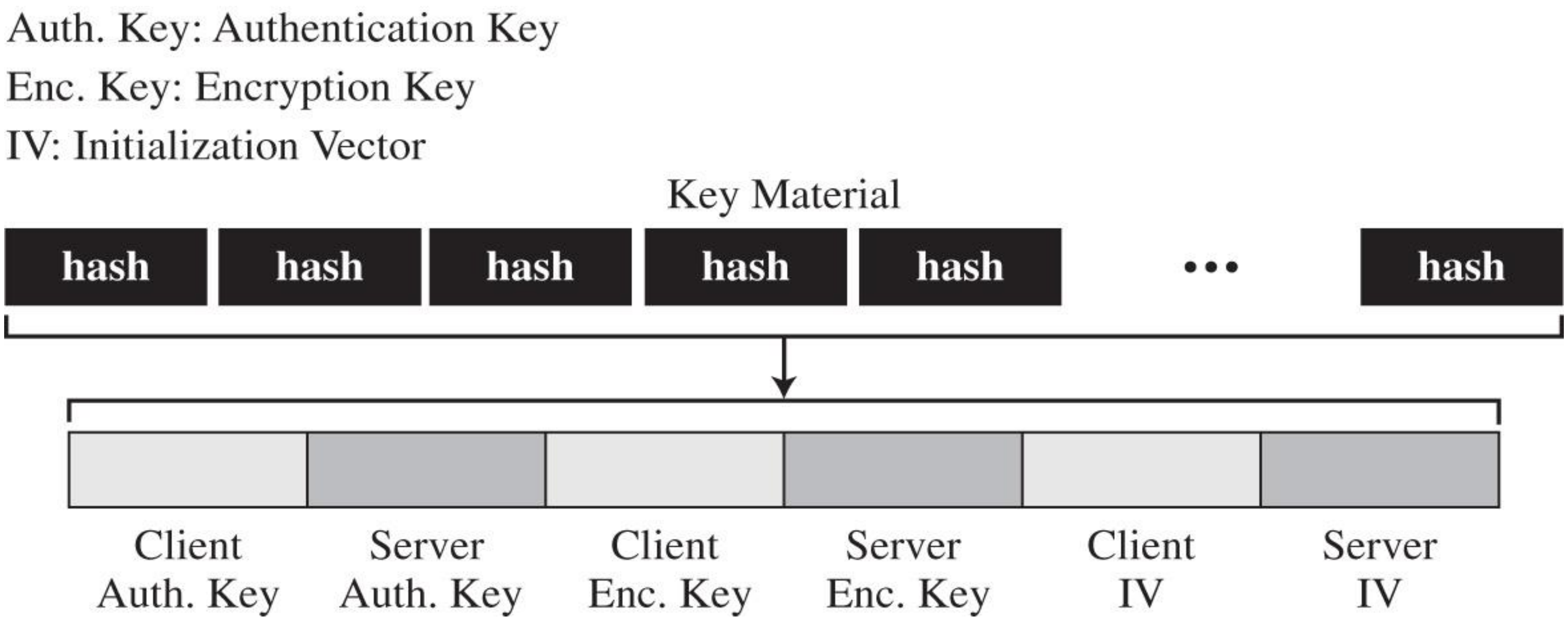
SSL KEY GENERATION



Nascenia IT

SSL KEY GENERATION

- Key material used to generate:
  - Keys for encryption and authentication (MAC)
  - IV's for block cipher chaining



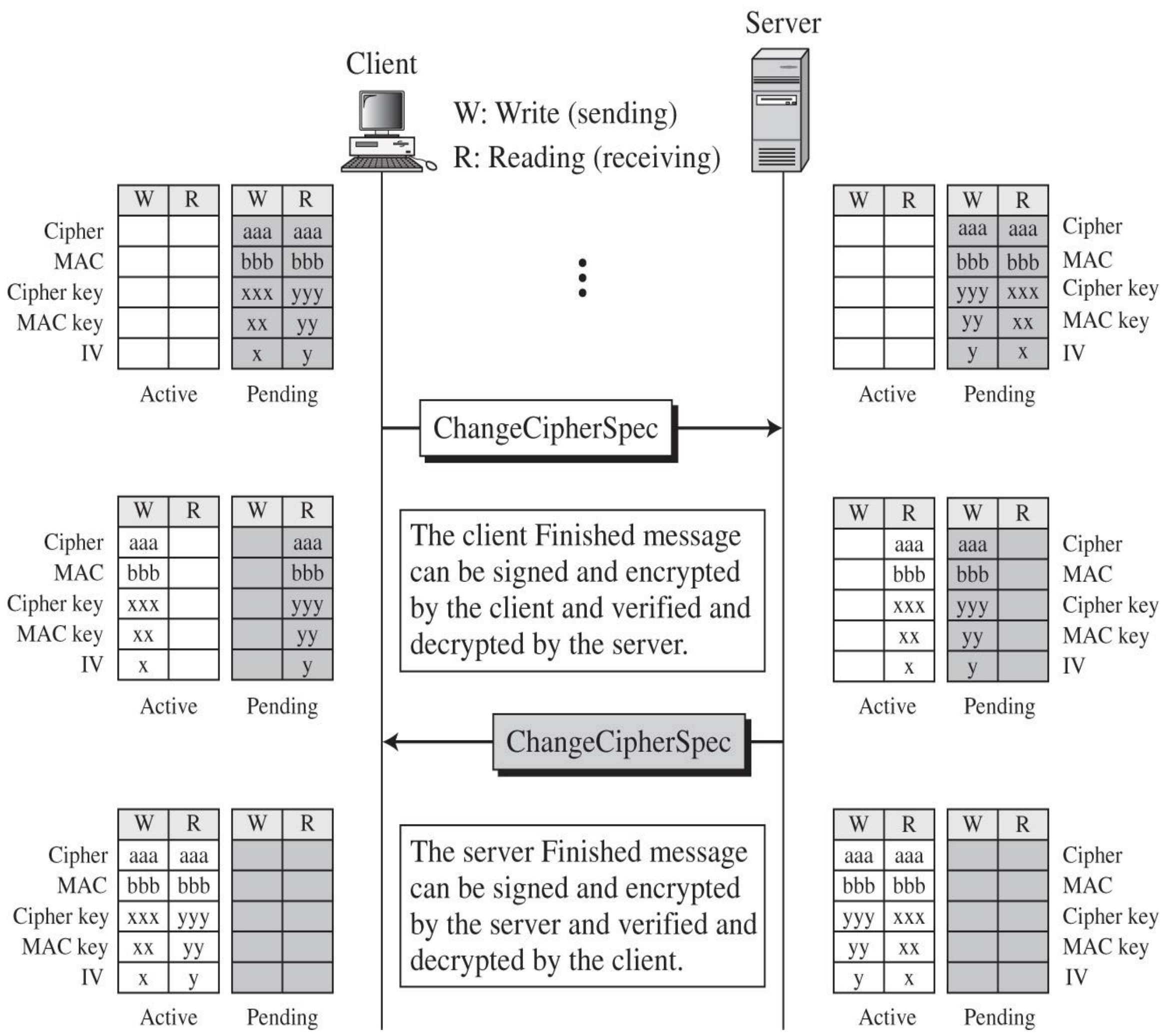
Nascenia IT

PHASE 4: FINAL HANDSHAKE

Client and server verify protocols and keys

- Sender
- signs/encrypts
- "finished"
- message

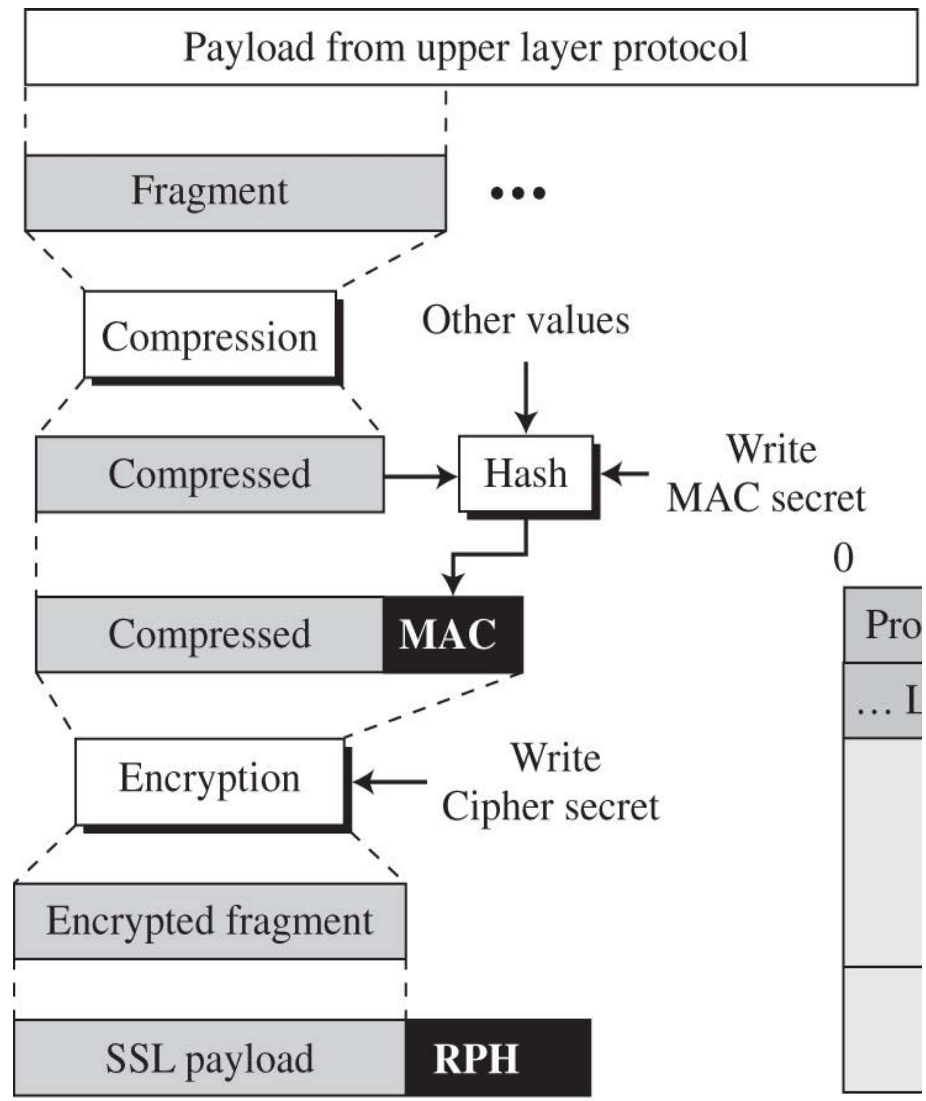
- Receiver
- decrypts/verifies
- message to
- confirm keys



Nascenia IT

SSL DATA TRANSMISSION

- Message broken into blocks
- Block compressed
- Compressed block hashed with authentication key to get MAC (message integrity)
- Compressed block + MAC encrypted with cipher key
-
- Encrypted block + record protocol header with version/length information sent



SSL DATA TRANSMISSION

- MAC algorithm is modified HMAC
  - Two stage hash with secret MAC key inserted at each stage
  - Values similar to IPAD and OPAD also inserted